EPFL - Computer Science

COM-402 Information Security and Privacy

Lecture 09 — November 17, 2025

Author: Jonathan Dutoit

Professor: Mathias Payer

Network Security

Learning goals

- Understand Network request
- Learn about Firewalls and Intrusion Detection Systems
- Data protection best practices

Outline

- Protecting the Network
- Protecting Remote Access
- Protecting the Perimeter
  - Firewalls and Zones
  - Firewall rules
  - Proxies
  - Intrusion detection systems
- Protecting the Workstation
- Protecting the Past (logging)
- Protecting Data (backups)

Security Breach at Target

Malware installed in Target's security and payment system, stealing details of every credit card used at the company's 1,797 US stores.

Security alerts on Dec 2, 2014. Target takes two weeks to react.

Result: 40 million credit card numbers stolen

The hacker(s) got in by compromising a third-party vendor.

Network Security Best Practices

Inside the network: segment the network physically:

- Different zones for different parts of the organization
- Demilitarized zone (DMZ)* to expose organization's external facing network on the internet

Towards ***outside*** secure communication

- TLS, IPSec, VPNs

Network (micro) Segmentation

Break down the network into segments based on system and data classification or into functional zones. Access from zone to zone can be managed by access control lists (ACLs) in routers or firewalls.

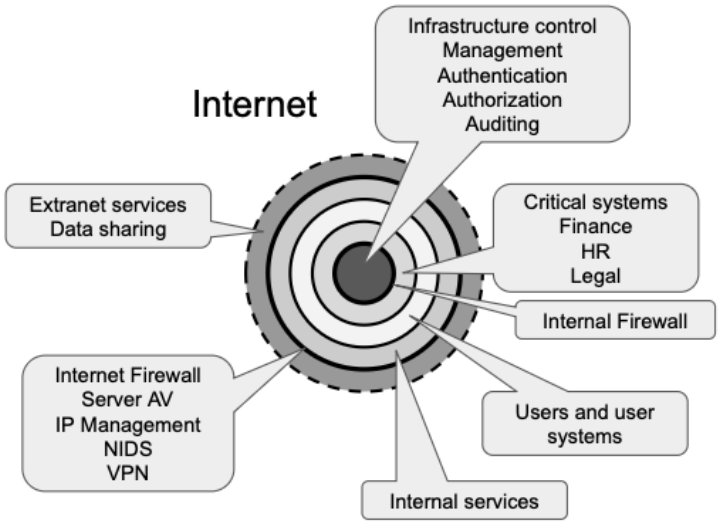
Mainly addresses two points:

- Prevents all-at-once compromise of facilities
- Protects the data center from external threats (little protection against internal threat agents)

Network Segmentation: Rings

In the classic *concentric architecture* access rights to services increase with each level, moving between levels is managed by access control.

One single ring may contain diverse services and many machines. An attack spreading in that ring may create significant damage.



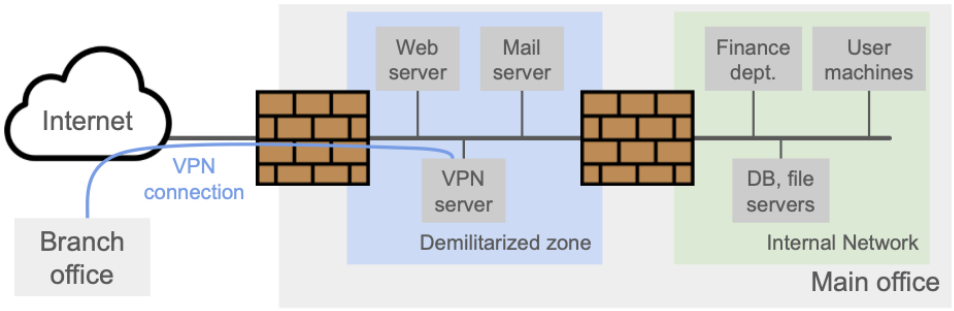
Advantage: **less complex**. Disadvantage: **Shared access between services that are maybe not linked**

Demilitarized Zone (DMZ)

A physical or logical subnetwork that contains and exposes an organization's external-facing services to an untrusted network, e.g. Iternet

An external network node can access only what is exposed in the DMZ

The most common services in DMZ are web, email, DNS, and VPN servers



There are two possible architectures: **single** firewall and **dual** firewall. One is less complex but less secure. The other is more complex and more secure.

Note that a single configuration mistake is more severe in a single firewall architecture.

Network Segmentation: Zones

Creating containment zones aims to stop attacks from spreading between zones. We want to have real fine-grained zones for a network.

Communication between zones goes through firewalls. This is closer to **least privilege** than rings.

The challenge is creating firewall rules for each case, it's easy to make mistakes and hard to keep rules updated/in sync.

Virtual Segmentation

How and where would you implement VLAN segmentation?

Network zones differ from physical zones, e.g., the HR zone spans two buildings

Virtual LAN (VLAN) technology compartmentalizes several layer 2 networks (ethernet) over the same cables and switches, any socket in any building can be configured to belong to any layer 2 network.

Virtual Routing and Forwarding (VRF) allows a single router to be part of several IP networks with VLAN and VRF, any socket in any location can be configured to belong to any ethernet and IP network

Virtual Machines (VMS) allows coalescing several servers and routers on a single hardware rack. The web server in the DMZ may actually be running on the same physical machine as the database of the internal back-end zone!

New Angle: "Zero Trust" Networks

Do not trust anybody, not even internal machines

- Goal: prevent lateral movement
- Continuously monitor and validate everything
- Install local firewall on internal machines (least privilege and access control)
- Encrypt all traffic between internal machines (microsegmentation)
- Use strong authentication even internally (MFA)

More work to configure machines, but with modern techniques (dockers, kubernetes) configuring and rolling out virtual machines can be automated.

Less work on configuring the network. Greatly reduces the impact if one machines is compromised.

Note: security comes at cost, if users have to fill 2FA 15x a day then there's an issue.

Protecting Remote Access

Virtual Private Networks

Virtual Private Networks (VPNs)

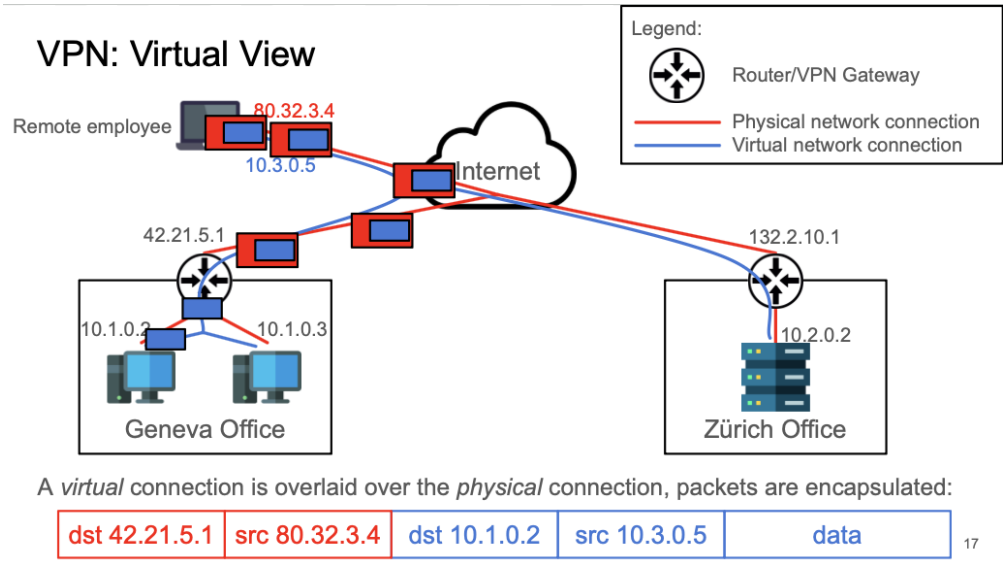
A VPN runs a ***private, virtual*** network over a ***public, physical*** network using two key components:

- Encryption to keep it private and for confidentiality
- Encapsulation packing IP packets inside IP packets to hide internal addresses and to transport private packets over the public network

A distant network or single machines can access a VPN through a VPN gateway

A single machine can run a VPN software to create a virtual interface, this interface has an IP address in the VPN network

Before a packet is sent over the public network, it is encrypted and encapsulated with an IP header with the public addresses.



Physical network interface has public IP address and a hardware address, virtual VPN interface shows up like just another network interface but ***without*** hardware address and an IP address from the private space!

VPN

Typical networks

- IP,sec, official IETF standard
- OpenVPN, open source software, based on TLS
- WireGuard, built into the Linux Kernel
- Proprietary protocols (e.g., Cisco AnyConnect), offer convenience in configuration and maintenance

Typical use

- Letting remote workers access the internal company network
- Interconnecting remote sites of a company
- For us: Acessing university resources (e.g, download papers)
- For us: Playing CTF and bridging networks between teams

VPN for Privacy

VPN to another country and access Internet from there

Your address is hidden by the one of the VPN gateways, the server in Paris thinks the connections are coming from Geneva

Danger: the VPN provider in Geneva sees your traffic

Protecting the Perimeter

Firewalls

Firewalls enforce network level access control

Typically at the border between Internet and the internal network (with larger networks having multiple zones and firewalls)

Firewalls operate at the network layer by analyzing metadata such as packet headers of IP, TCP, and UDP. Firewalls are oblivious of the application for which the packets are transmitted

Firewall Within the Networks

Protecting the network with firewalls at the perimeter is insufficient due to lateral movement of attackers

Propagation of attacks is prevented by segmenting the internal network

Example: EPFL network segmentation

- Most machines are in the generic **EPFL** zone
- All machines accessible from Internet must be located in the **untrusted** zone
- Machines in **untrust** cannot connect to machines in **EPFL**, but opposite is OK
- The data about your grades and professors' salary are behind a firewall in the back-end of the **Data Center** zone
- In general, each zone only connect to zones of lesser security. Remember MAC?

Best Practices for Firewall Rules: Prefer Allowlist

One line per connection/data flow from given source to given destination

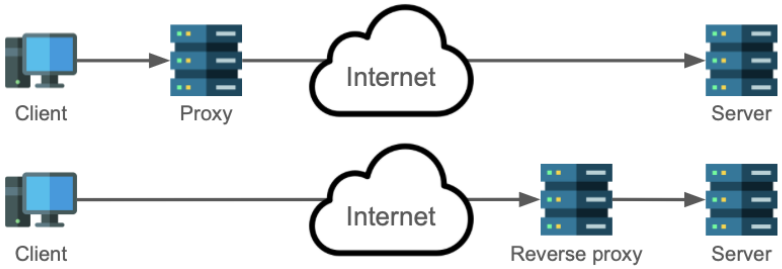
Example:

- Allow only HTTP and HTTPS from internal zone to Internet
- Allow SSH from Internet only to one server

Principle of **default deny**: the last rule denies all traffic that has not explicitly been allowed before

Proxies

Proxies operate at the ***application level*** and act as a ***server to the client*** and as a ***client to the server*** (compare to Firewalls that operate at the network level)



- Direct proxies protect users when they access servers on the Internet
- Reverse proxies protect servers when accessed by users from the Internet

Web Proxies

Goal: protect users surfing the web against threat by reducing attack surface.

- Analyse all data downloaded from the web
- Block access to dangerous sites

The browser must be configured to use the proxy

The firewall can be configured to only allow the proxy to access web sites, users cannot surf the net if they don't go through the proxy.

Web Proxies for HTTPS

MitM Connections

The proxy can be configured to intercept HTTPS traffic Rather than forwarding the handshake, it pretends to be the server

- To achieve this it must generate fake certificates
- The browser sees the fake certificate and wants to generate an error
- All browsers of the company must be configured to accept fake certificates from the proxy

Passthrough By default, HTTPS traffic is encrypted from the client to the server

- The proxy forwards the TLS handshake between the client and the server
- It just acts like a passthrough
- The client receives the original certificate
- The proxy only sees encrypted traffic: it cannot filter dangerous data

Going Forward

MitM proxying is getting more and more difficult due to technological advanced such as:

- HSTS for enforcing HTTPS
- certificate pinning for preventing certificate spoofing
- perfect forward secrecy of TLS 1.3 for using ephemeral keys to prevent later decryption

Mail Gateways

Mail gateways act both as proxy and reverse proxy: all outgoing mail is stored on the mail gateway before being forwarded to the internet

All incoming mail is intercepted by the gateway before being forwarded to the users' mailbox

Mail gateways typically offer:

- antivirus protection
- incoming and outgoing spam protection

Web Application Firewall (WAF)

A WAF is the typical example of reverse proxy with the goal of protecting a web server against malicious requests from the Internet

It analyses requests, and if it deems them safe, forwards them to the real server

WAFs typically offer the following protections:

- Block any request that seems to contain an attack (XSS, SQL, injection)
- Limit the number of requests to protect against DoS attacks (your site will still be unreachable, but at least your internal server still works)
- Block an IP address for a certain time after detection of an attack
- Authenticate users (to prohibit unauthenticated users from interacting

Example: modSecurity

modSecurity started as an Apache web server module and now protects diverse web servers and reverse proxies

There is a free open source set of rules (core rule set) with thousands of rules

SQL injection examples:

- "@rx (?i)union.*?select.*?from"
- "@rx (?i:sleep∗?∗?∗?—benchmark.∗? .∗?)"

Intrusion Detection Systems

An IDS inspects traffic for ***all*** applications to detect potential detections:

- Generates alerts if it thinks it saw an attack
- Called an Intrusion Prevention System (IPS) when it also blocks such traffic

Two technologies:

- Signatures-based systems
- Anomaly-based systems

Possible issues:

- False positives (too many alarms)
- False negatives (too many successful attacks)

Signature-based IDS

Compares network traffic against signatures from a pattern database, like a WAF does for web traffic

Possible issues

- Requires previous knowledge of an attack to create a signature (false negatives for new attacks)
- Matched signature does not always mean successful attack, e.g., signature for a Linux vulnerability in traffic of a Windows server (false positives)

Signature examples:

- High number of failed login attempts
- URLs with extra long parameters (buffer overflows?)
- Exploiting a specific vulnerability: Cisco IOS invalid IKE fragment length memory corruption or exhaustion attempt

Signature-based IDS: Snort

Snort sniffs traffic in front of your firewall to detect potential attacks. It sends alarms and/or updates to firewall, blocking the attacker.

Large database of free rules maintained by community. Commercial database of additional rules.

Anomaly-based Systems

Goal: detect unknown attacks

The IDS create a ***traffic profile*** during normal operation to calibrate.

During monitoring, it looks for unusual packets, e.g., growth in port scans

- Might not detect an SQL injection (extra characters in username)
- Might notice a 200MB transfer of password hashes from the database

Generates a lot of false positives and negatives (anomaly != attack)

- Very hot applications for machine learning techniques!

Base Rate Fallacy

Image a situation where:

- the probability that a packet is part of an attack is 1 in 10,000
- the false positive rate of your IDS is 1% for a single packet
- the false negative rate is 1% for a single packet
- its 2am, you receive an alert from your IDS

The chance that that this is a true alarm is of 1% only!! You should stay in bed.

Protecting a Workstation

Prevent exploitable bugs:

- Ensure automatic update of the OS
- Ensure automatic update of the applications

Prevent known malware:

- Install antivirus or use built-in ones (e.g., Windows Defender)
- Install applications from trusted sources (market of packet manager)

Prevent unknown malware:

- Prohibit users from installing applications
- Restrict write access to directories that contain documents, not programs.

AntiVirus is no longer as effective as campaigns are very short-lived

Preventing Privilege Escalation

Verify that all access rights are correctly set on programs and libraries.

Typical issue: a program that is run by System is writable by any user, the attacker replaces the program by a malicious program and reboots the machine

Make sure that all program are regularly patched to fix any known vulnerabilities

Make sure that the hard disk is encrypted, if not, attackers can boot form USB (or remove the disk) and have full access rights to all files.

Protecting History: Logging

Keeping audit trails (aka logs) is an import part of network security. It helps identify security incidents, monitor policy violations, and non reputation control. Massive amount of logs being used by different services.

Things that **you should never log**:

- Passwords!
- Religious, ideological, political or trade union-related views or activities
- Social security measures
- Administrative or criminal proceedings and sanctions
- etc...

Protecting Data: Backups

Backup Recommendations

Backup types: full, incremental (data that changed since last backup), differential (data that changes since last full backup)

3-2-1 rule:

- 3 copies of the data
- On 2 different types of media (e.g, disk and tape)
- 1 stored off-site

Backup Content

Backups are made differently depending on the type of data. Like virtual machines, databases, file storage all have different backup strategies. For instance databases have their own tools to backup and restore the content of their tables.

Disaster Recovery Plan

Making backups is not sufficient. Backups also need to be tested regularly through ***restoration tests***, i.e., to ensure we can recover data from backups

A Disaster Recovery Plan (DRP) records, in detail, how to rebuild a system in case of a major failure.